



IUS
INSTITUT
UNIVERSITAIRE
DES SCIENCES

INSTITUT UNIVERSITAIRE DES SCIENCES (IUS)

Faculté des sciences et des technologies (FST)

TD N° 5– Administration Systèmes

Préparé par : Brian ANTOINE

Présenté à: M. Ismaël SAINT AMOUR

Niveau : L3

Date: 03/04/2026

L'objectif de ce TD est de :

1. sécuriser un serveur Linux
2. protéger les accès SSH
3. filtrer le trafic réseau
4. bloquer les attaques automatisées
5. analyser la sécurité d'un système
6. installer un outil d'audit de sécurité
7. interpréter un rapport d'audit
8. identifier les failles potentielles
9. proposer des améliorations de sécurité

❖ Vérification des ports ouverts : ss -tln

```
bribri@bribri1:~$ ss -tln
```

Netid	State	Recv-Q	Send-Q	Local Address:Port	Peer Address:Port	Process
udp	UNCONN	0	0	127.0.0.54:53	0.0.0.0:*	
udp	UNCONN	0	0	127.0.0.53:53	0.0.0.0:*	
udp	UNCONN	0	0	172.20.10.2:53:68	0.0.0.0:*	
udp	UNCONN	0	0	0.0.0.0:111	0.0.0.0:*	
udp	UNCONN	0	0	:::111	:::*	
udp	UNCONN	0	0	[fe80::a00:27ff:fe07:48de]:546	:::*	
tcp	LISTEN	0	4096	127.0.0.53:53	0.0.0.0:*	
tcp	LISTEN	0	4096	127.0.0.54:53	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:2222	0.0.0.0:*	
tcp	LISTEN	0	100	0.0.0.0:25	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:111	0.0.0.0:*	
tcp	LISTEN	0	4096	:::2222	:::*	
tcp	LISTEN	0	100	:::25	:::*	
tcp	LISTEN	0	4096	:::111	:::*	
tcp	LISTEN	0	511	:::80	:::*	

```
bribri@bribri1:~$
```

❖ Vérification des services actifs : systemctl list-units --type=service

```
blk-availability.service loaded active exited Availability of block devices
console-setup.service loaded active exited Set console font and keymap
cron.service loaded active running Regular background program processing daemon
dbus.service loaded active running D-Bus System Message Bus
fail2ban.service loaded active running Fail2Ban Service
finalrd.service loaded active exited Create final runtime dir for shutdown pivot root
getty@tty1.service loaded active running Getty on tty1
keyboard-setup.service loaded active exited Set the console keyboard layout
kmod-static-nodes.service loaded active exited Create List of Static Device Nodes
lvm2-monitor.service loaded active exited Monitoring of LVM2 mirrors, snapshots etc. using dmeventd or progress polling
ModemManager.service loaded active running Modem Manager
multipathd.service loaded active running Device-Mapper Multipath Device Controller
networkd-dispatcher.service loaded active running Dispatcher daemon for systemd-networkd
nftables.service loaded failed failed nftables
plymouth-quit-wait.service loaded active exited Hold until boot process finishes up
plymouth-quit.service loaded active exited Terminate Plymouth Boot Screen
plymouth-read-write.service loaded active exited Tell Plymouth To Write Out Runtime Data
plymouth-start.service loaded active exited Show Plymouth Boot Screen
polkit.service loaded active running Authorization Manager
postfix.service loaded active exited Postfix Mail Transport Agent
postfix@-.service loaded active running Postfix Mail Transport Agent (instance -)
rpcbind.service loaded active running RPC bind portmap service
rsyslog.service loaded active running System Logging Service
setvtrgb.service loaded active exited Set console scheme
snapd.apparmor.service loaded active exited Load AppArmor profiles managed internally by snapd
snapd.seeded.service loaded active exited Wait until snapd is fully seeded
snapd.service loaded active running Snap Daemon
ssh.service loaded active running OpenBSD Secure Shell server
sysstat.service loaded active exited Resets System Activity Logs
systemd-binfmt.service loaded active exited Set Up Additional Binary Formats
systemd-journal-flush.service loaded active exited Flush Journal to Persistent Storage
systemd-journald.service loaded active running Journal Service
systemd-logind.service loaded active running User Login Management
systemd-modules-load.service loaded active exited Load Kernel Modules
systemd-networkd-wait-online.service loaded active exited Wait for Network to be Configured
systemd-networkd.service loaded active running Network Configuration
systemd-random-seed.service loaded active exited Load/Save OS Random Seed
systemd-remount-fs.service loaded active exited Remount Root and Kernel File Systems
systemd-resolved.service loaded active running Network Name Resolution
systemd-sysctl.service loaded active exited Apply Kernel Variables
systemd-timesyncd.service loaded active running Network Time Synchronization
systemd-tmpfiles-setup-dev-early.service loaded active exited Create Static Device Nodes in /dev gracefully
systemd-tmpfiles-setup-dev.service loaded active exited Create Static Device Nodes in /dev
systemd-tmpfiles-setup.service loaded active exited Create Volatile Files and Directories
systemd-udev-trigger.service loaded active exited Coldplug All udev Devices
lines 1-49
[1]+ Stopped systemctl list-units --type=service
bribri@bribri1:~$
```

❖ Vérifier les utilisateurs :

```
bribri@bribri1:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
systemd-timesync:x:997:997:systemd Time Synchronization:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon,,,:/usr/lib/dhcpcd:/bin/false
messagebus:x:101:102::/nonexistent:/usr/sbin/nologin
systemd-resolve:x:992:992:systemd Resolver:/:/usr/sbin/nologin
pollinate:x:102:1::/var/cache/pollinate:/bin/false
polkitd:x:991:991:User for polkitd:/:/usr/sbin/nologin
syslog:x:103:104::/nonexistent:/usr/sbin/nologin
uidd:x:104:105::run/uidd:/usr/sbin/nologin
tcpdump:x:105:107::/nonexistent:/usr/sbin/nologin
tss:x:106:108:TPM software stack,,,:/var/lib/tpm:/bin/false
landscape:x:107:109::/var/lib/landscape:/usr/sbin/nologin
fwupd-refresh:x:989:989:Firmware update daemon:/var/lib/fwupd:/usr/sbin/nologin
usbmux:x:108:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
bribri:x:1000:1000:bribri:/home/bribri:/bin/bash
_rpc:x:109:65534::run/rpcbind:/usr/sbin/nologin
postfix:x:110:111:/var/spool/postfix:/usr/sbin/nologin
nagios:x:111:113:/var/lib/nagios:/usr/sbin/nologin
sshd:x:112:65534::run/sshd:/usr/sbin/nologin
bribri@bribri1:~$
```

❖ Éditer la configuration SSH :

```
GNU nano 7.2 /etc/ssh/sshd_config *
# be allowed through the KbdInteractiveAuthentication and
# PasswordAuthentication. Depending on your PAM configuration,
# PAM authentication via kbdInteractiveAuthentication may bypass
# the setting of "PermitRootLogin prohibit-password".
# If you just want the PAM account and session checks to run without
# PAM authentication, then enable this but set PasswordAuthentication
# and KbdInteractiveAuthentication to 'no'.
UsePAM yes

#AllowAgentForwarding yes
#AllowTcpForwarding yes
#GatewayPorts no
X11Forwarding yes
#X11DisplayOffset 10
#X11UseLocalhost yes
#PermitTTY yes
PrintMotd no
#PrintLastLog yes
#TCPKeepAlive yes
#PermitUserEnvironment no
#Compression delayed
#ClientAliveInterval 0
#ClientAliveCountMax 3
#UseDNS no
#PidFile /run/sshd.pid
#MaxStartups 10:30:100
#PermitTunnel no
#ChrootDirectory none
#VersionAddendum none

# no default banner path
#Banner none

# Allow client to pass locale environment variables
AcceptEnv LANG LC_*

# override default of no subsystems
Subsystem sftp /usr/lib/openssh/sftp-server

# Example of overriding settings on a per-user basis
#Match User anoncvs
#    X11Forwarding no
#    AllowTcpForwarding no
#    PermitTTY no
#    ForceCommand cvs server
-
⌘ Help      ⌘ Write Out  ⌘ Where Is   ⌘ Cut        ⌘ Execute    ⌘ Location   ⌘ Undo      ⌘ Set Mark   ⌘ To Bracket ⌘ Previous
⌘ Exit      ⌘ Read File  ⌘ Replace    ⌘ Paste      ⌘ Justify    ⌘ Go To Line ⌘ Redo      ⌘ Copy       ⌘ Where Was ⌘ Next
```

```
GNU nano 7.2 /etc/ssh/sshd_config *
# be allowed through the KbdInteractiveAuthentication and
# PasswordAuthentication. Depending on your PAM configuration,
# PAM authentication via KbdInteractiveAuthentication may bypass
# the setting of "PermitRootLogin prohibit-password".
# If you just want the PAM account and session checks to run without
# PAM authentication, then enable this but set PasswordAuthentication
# and KbdInteractiveAuthentication to 'no'.
UsePAM yes

#AllowAgentForwarding yes
#AllowTcpForwarding yes
#GatewayPorts no
X11Forwarding yes
#X11DisplayOffset 10
#X11UseLocalhost yes
#PermitTTY yes
PrintMotd no
#PrintLastLog yes
#TCPKeepAlive yes
#PermitUserEnvironment no
#Compression delayed
#ClientAliveInterval 0
#ClientAliveCountMax 3
#UseDNS no
#PidFile /run/sshd.pid
#MaxStartups 10:30:100
#PermitTunnel no
#ChrootDirectory none
#VersionAddendum none

# no default banner path
#Banner none

# Allow client to pass locale environment variables
AcceptEnv LANG LC_*

# override default of no subsystems
Subsystem sftp /usr/lib/openssh/sftp-server

# Example of overriding settings on a per-user basis
#Match User anoncvs
#      X11Forwarding no
#      AllowTcpForwarding no
#      PermitTTY no
#      ForceCommand cvs server
-
^G Help      ^O Write Out  ^W Where Is   ^K Cut        ^T Execute    ^C Location   M-U Undo      M-A Set Mark  M-I To Bracket M-Q Previous
^X Exit      ^R Read File  ^N Replace    ^P Paste      ^J Justify    ^_ Go To Line  M-B Redo      M-X Copy      M-O Where Was  M-W Next
```

❖ Redémarrage du service :

```
bribri@bribri1:~$ sudo systemctl restart ssh
Warning: The unit file, source configuration file or drop-ins of ssh.service changed on disk. Run 'systemctl daemon-reload' to reload units.
bribri@bribri1:~$ sudo systemctl daemon-reload
bribri@bribri1:~$ sudo systemctl restart ssh
bribri@bribri1:~$
```

3. Configuration du Firewall (UFW)

❖ Installer UFW :

```
bribri@bribri1:~$ sudo apt install ufw -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
ufw is already the newest version (0.36.2-6).
0 upgraded, 0 newly installed, 0 to remove and 0 not upgraded.
bribri@bribri1:~$ sudo ufw default deny incoming
Default incoming policy changed to 'deny'
(be sure to update your rules accordingly)
bribri@bribri1:~$ sudo ufw default allow outgoing
Default outgoing policy changed to 'allow'
(be sure to update your rules accordingly)
bribri@bribri1:~$
```

❖ Autoriser uniquement les ports nécessaires :

```
bribri@bribri1:~$ sudo ufw allow 2222/tcp
Rule added
Rule added (v6)
bribri@bribri1:~$ sudo ufw allow 80/tcp
Rule added
Rule added (v6)
bribri@bribri1:~$ sudo ufw allow 443/tcp
Rule added
Rule added (v6)
bribri@bribri1:~$ _
```

❖ Activer le firewall

```
bribri@bribri1:~$ sudo ufw enable
Firewall is active and enabled on system startup
```

❖ Vérifier les règles actives :

```
bribri@bribri1:~$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
22 ALLOW IN Anywhere
80 ALLOW IN Anywhere
443 ALLOW IN Anywhere
2222/tcp ALLOW IN Anywhere
80/tcp ALLOW IN Anywhere
443/tcp ALLOW IN Anywhere
22 (v6) ALLOW IN Anywhere (v6)
80 (v6) ALLOW IN Anywhere (v6)
443 (v6) ALLOW IN Anywhere (v6)
2222/tcp (v6) ALLOW IN Anywhere (v6)
80/tcp (v6) ALLOW IN Anywhere (v6)
443/tcp (v6) ALLOW IN Anywhere (v6)

bribri@bribri1:~$
```

4. Protection contre les attaques brute force (Fail2Ban)

```
bribri@bribri1:~$ sudo apt install fail2ban -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
fail2ban is already the newest version (1.0.2-3ubuntu0.1).
0 upgraded, 0 newly installed, 0 to remove and 0 not upgraded.
bribri@bribri1:~$ _
```

❖ Préparation du serveur : lynis

➤ Installation de lynis

```
bribri@bribri1:~$ sudo apt install lynis -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following additional packages will be installed:
  menu
Suggested packages:
  apt-listbugs debsecan debsums tripwire sanhain aide menu-110n gksu | kde-cli-tools | ktsuss
The following NEW packages will be installed:
  lynis menu
0 upgraded, 2 newly installed, 0 to remove and 6 not upgraded.
Need to get 602 kB of archives.
After this operation, 3,202 kB of additional disk space will be used.
Get:1 http://archive.ubuntu.com/ubuntu noble/universe amd64 lynis all 3.0.9-1 [226 kB]
Get:2 http://archive.ubuntu.com/ubuntu noble/universe amd64 menu amd64 2.1.50 [377 kB]
Fetched 602 kB in 35s (17.1 kB/s)
Selecting previously unselected package lynis.
(Reading database ... 132603 files and directories currently installed.)
Preparing to unpack .../archives/lynis_3.0.9-1_all.deb ...
Unpacking lynis (3.0.9-1) ...
Selecting previously unselected package menu.
Preparing to unpack .../archives/menu_2.1.50_amd64.deb ...
Unpacking menu (2.1.50) ...
Setting up lynis (3.0.9-1) ...
Created symlink /etc/systemd/system/timers.target.wants/lynis.timer -> /usr/lib/systemd/system/lynis.timer.
lynis.service is a disabled or a static unit, not starting it.
Setting up menu (2.1.50) ...
Processing triggers for install-info (7.1-3build2) ...
Processing triggers for man-db (2.12.0-4build2) ...
Processing triggers for menu (2.1.50) ...
Scanning processes...
Scanning linux images...

Pending kernel upgrade!
Running kernel version:
  6.8.0-106-generic
Diagnostics:
  The currently running kernel version is not the expected kernel version 6.8.0-107-generic.

Restarting the system to load the new kernel will not be handled automatically, so you should consider rebooting.

No services need to be restarted.

No containers need to be restarted.

No user sessions are running outdated binaries.

No VM guests are running outdated hypervisor (qemu) binaries on this host.
bribri@bribri1:~$
```


1. Audit initial avec lynis

```
- Checking Metalog status           [ NOT FOUND ]
- Checking RSyslog status           [ FOUND ]
- Checking RFC 3195 daemon status   [ NOT FOUND ]
- Checking minilogd instances       [ NOT FOUND ]
- Checking logrotate presence       [ OK ]
- Checking remote logging           [ NOT ENABLED ]
- Checking log directories (static list) [ DONE ]
- Checking open log files           [ DONE ]
- Checking deleted files in use     [ FILES FOUND ]

[+] Insecure services
-----
- Installed inetd package           [ NOT FOUND ]
- Installed xinetd package          [ OK ]
- xinetd status                     [ OK ]
- Installed rsh client package       [ OK ]
- Installed rsh server package       [ OK ]
- Installed telnet client package    [ OK ]
- Installed telnet server package    [ NOT FOUND ]
- Checking NIS client installation   [ OK ]
- Checking NIS server installation   [ OK ]
- Checking TFTP client installation  [ OK ]
- Checking TFTP server installation  [ OK ]

[+] Banners and identification
-----
- /etc/issue                        [ FOUND ]
- /etc/issue contents               [ WEAK ]
- /etc/issue.net                    [ FOUND ]
- /etc/issue.net contents           [ WEAK ]

[+] Scheduled tasks
-----
- Checking crontab and cronjob files [ DONE ]

[+] Accounting
-----
- Checking accounting information    [ NOT FOUND ]
- Checking sysstat accounting data   [ DISABLED ]
- Checking auditd                    [ NOT FOUND ]

[+] Time and Synchronization
-----
- NTP daemon found: systemd (timesyncd) [ FOUND ]
- Checking for a running NTP daemon or client [ OK ]
- Last time synchronization         [ 101s ]

[+] Cryptography
```

```
★ Harden the system by installing at least one malware scanner, to perform periodic file system scans [HRDN-7230]
- Solution : Install a tool like rkhunter, chkrootkit, OSSEC
  https://cisofy.com/lynis/controls/HRDN-7230/
```

Follow-up:

- Show details of a test (lynis show details TEST-ID)
- Check the logfile for all details (less /var/log/lynis.log)
- Read security controls texts (<https://cisofy.com>)
- Use --upload to upload data to central system (Lynis Enterprise users)

Lynis security scan details:

```
Hardening index : 69 [##### ]
Tests performed : 268
Plugins enabled : 1
```

Components:

- Firewall [V]
- Malware scanner [X]

Scan mode:

```
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]
```

Lynis modules:

- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]

Files:

- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat

Lynis 3.0.9

Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

2007-2021, CISOfy - <https://cisofy.com/lynis/>
Enterprise support available (Compliance, plugins, interface and tools)

```
[TTP]: Enhance Lynis audits by adding your settings to custom.prfl (see /etc/lynis/default.prfl for all settings)
```

```
bribr1@bribr11:~$ _
```

➤ Audit ciblé sur la sécurité SSH avant durcissement

sudo lynis audit system --tests "SSH"

```
-----
* This release is more than 4 months old. Check the website or GitHub to see if there is an update available. [LYNIS]
https://cisofy.com/lynis/controls/LYNIS/

Follow-up:
-----
- Show details of a test (lynis show details TEST-ID)
- Check the logfile for all details (less /var/log/lynis.log)
- Read security controls texts (https://cisofy.com)
- Use --upload to upload data to central system (Lynis Enterprise users)

=====

Lynis security scan details:

Hardening index : 1 [# ]
Tests performed : 0
Plugins enabled : 1

Components:
- Firewall [X]
- Malware scanner [X]

Scan mode:
Normal [V] Forensics [] Integration [] Pentest []

Lynis modules:
- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat

=====

Lynis 3.0.9

Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

2007-2021, CISOfy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)

=====

[TIP]: Enhance Lynis audits by adding your settings to custom.prf (see /etc/lynis/default.prf for all settings)

bribr1@bribr11:~$
```

➤ Identification de 3 suggestions

```
suggestion[]=KRN-5020 If not required, consider explicit disabling of core dump in /etc/security/limits.conf file|-|-|
suggestion[]=AUTH-9229 Check PAM configuration, add rounds if applicable and expire passwords to encrypt with new values|-|-|
suggestion[]=AUTH-9230 Configure password hashing rounds in /etc/login.defs|-|-|
suggestion[]=AUTH-9282 Install a PAM module for password strength testing like pam_cracklib or pam_passwdcat|-|-|
suggestion[]=AUTH-9282 When possible set expire dates for all password protected accounts|-|-|
suggestion[]=AUTH-9286 Configure minimum password age in /etc/login.defs|-|-|
suggestion[]=AUTH-9286 Configure maximum password age in /etc/login.defs|-|-|
suggestion[]=AUTH-9320 Default unask in /etc/login.defs could be more strict like #27|-|-|
suggestion[]=FILE-6310 To decrease the impact of a full /home file system, place /home on a separate partition|-|-|
suggestion[]=FILE-6310 To decrease the impact of a full /tmp file system, place /tmp on a separate partition|-|-|
suggestion[]=FILE-6310 To decrease the impact of a full /var file system, place /var on a separate partition|-|-|
suggestion[]=GSS-1000 Disable drivers like udev storage when not used, to prevent unauthorized storage or data theft|-|-|
suggestion[]=HME-4400 Check DNS configuration for the dns domain name|-|-|
suggestion[]=HME-4404 Add the IP name and FQDN to /etc/hosts for proper name resolving|-|-|
suggestion[]=PKGS-7270 Install debsumo utility for the verification of packages with known good database|-|-|
suggestion[]=PKGS-7294 Install package apt-show-versions for patch management purposes|-|-|
suggestion[]=NETW-3200 Determine if protocol 'dcbp' is really needed on this system|-|-|
suggestion[]=NETW-3200 Determine if protocol 'dcbp' is really needed on this system|-|-|
suggestion[]=NETW-3200 Determine if protocol 'rds' is really needed on this system|-|-|
suggestion[]=NETW-3200 Determine if protocol 'tipc' is really needed on this system|-|-|
suggestion[]=MAIL-9810 You are advised to hide the mail_name (option: smtp_banner) from your postfix configuration. Use postfixconf -e or change your main.cf file
(/etc/postfix/main.cf)|-|-|
suggestion[]=MAIL-9820 Disable_vrfy_command[Disable the 'VRFY' command]disable_vrfy_command=no|text:run postfixconf -e disable_vrfy_command=yes to change the value
|
suggestion[]=FIRE-4513 Check iptables rules to see which rules are currently not used|-|-|
suggestion[]=HTTP-6540 Install Apache mod_evasive to guard webserver against DoS/brute force attempts|-|-|
suggestion[]=HTTP-6543 Install Apache mod_security to guard webserver against web application attacks|-|-|
suggestion[]=SSH-7400 Consider hardening SSH configuration[allowtcpforwarding (set YES to NO)]-|-|
suggestion[]=SSH-7400 Consider hardening SSH configuration[clientalivecountmax (set 3 to 2)]-|-|
suggestion[]=SSH-7400 Consider hardening SSH configuration[loglevel (set INFO to VERBOSE)]-|-|
suggestion[]=SSH-7400 Consider hardening SSH configuration[maxauthtries (set 6 to 3)]-|-|
suggestion[]=SSH-7400 Consider hardening SSH configuration[maxsessions (set 10 to 2)]-|-|
suggestion[]=SSH-7400 Consider hardening SSH configuration[tcpkeepalive (set YES to NO)]-|-|
suggestion[]=SSH-7400 Consider hardening SSH configuration[x11forwarding (set YES to NO)]-|-|
suggestion[]=SSH-7400 Consider hardening SSH configuration[allowagentforwarding (set YES to NO)]-|-|
suggestion[]=LOGG-2154 Enable logging to an external logging host for archiving purposes and additional protection|-|-|
suggestion[]=LOGG-2190 Check what deleted files are still in use and why|-|-|
suggestion[]=BANN-7120 Add a legal banner to /etc/issue, to warn unauthorized users|-|-|
suggestion[]=BANN-7130 Add legal banner to /etc/issue.net, to warn unauthorized users|-|-|
suggestion[]=ACCT-9622 Enable process accounting|-|-|
suggestion[]=ACCT-9626 Enable ssssd to collect accounting (disabled)-|-|-|
suggestion[]=ACCT-9628 Enable auditd to collect audit information|-|-|
suggestion[]=FINT-4350 Install a file integrity tool to monitor changes to critical and sensitive files|-|-|
suggestion[]=TOL-5902 Determine if automation tools are present for system management|-|-|
suggestion[]=FILE-7524 Consider restricting file permissions[See screen output or log file|text:Use chmod to change file permissions]
suggestion[]=KRN-6000 One or more sysctl values differ from the scan profile and could be tweaked[Change sysctl value or disable test (skIp-test+KRN-6000:csy
sc1|help)]
suggestion[]=HON-7230 Harden the system by installing at least one malware scanner, to perform periodic file system scans|-|Install a tool like rkhunter, chkrootkit, OSSEC|
bribr1@bribr11:~$
```

➤ Installation de : libpam-tmpdir / apt-listchanges/ apt-listbugs

```
bribri@bribri1:~$ sudo apt install libpam-tmpdir
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
libpam-tmpdir is already the newest version (0.09build1).
0 upgraded, 0 newly installed, 0 to remove and 6 not upgraded.
bribri@bribri1:~$
```

```
bribri@bribri1:~$ sudo apt install apt-listchanges
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
apt-listchanges is already the newest version (3.27).
0 upgraded, 0 newly installed, 0 to remove and 6 not upgraded.
bribri@bribri1:~$ _
```

2. Mesure de durcissement

Sécurisation de SSH

```
# be allowed through the KbdInteractiveAuthentication and
# PasswordAuthentication. Depending on your PAM configuration,
# PAM authentication via KbdInteractiveAuthentication may bypass
# the setting of "PermitRootLogin prohibit-password".
# If you just want the PAM account and session checks to run without
# PAM authentication, then enable this but set PasswordAuthentication
# and KbdInteractiveAuthentication to 'no'.
UsePAM yes

#AllowAgentForwarding yes
#AllowTcpForwarding yes
#GatewayPorts no
X11Forwarding yes
#X11DisplayOffset 10
#X11UseLocalhost yes
#PermitTTY yes
PrintMotd no
#PrintLastLog yes
#TCPKeepAlive yes
#PermitUserEnvironment no
#Compression delayed
#ClientAliveInterval 0
#ClientAliveCountMax 3
#UseDNS no
#PidFile /run/sshd.pid
#MaxStartups 10:30:100
#PermitTunnel no
#ChrootDirectory none
#VersionAddendum none

# no default banner path
#Banner none

# Allow client to pass locale environment variables
AcceptEnv LANG LC_*

# override default of no subsystems
Subsystem sftp /usr/lib/openssh/sftp-server

# Example of overriding settings on a per-user basis
#Match User anoncvs
#    X11Forwarding no
#    AllowTcpForwarding no
#    PermitTTY no
#    ForceCommand cvs server

bribri@bribri1:~$ sudo systemctl restart ssh
bribri@bribri1:~$ _
```

➤ **Activer le pare-feu (firewall)**

Installer UFW :

```
bribri@bribri1:~$ sudo apt install ufw -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
ufw is already the newest version (0.36.2-6).
0 upgraded, 0 newly installed, 0 to remove and 0 not upgraded.
bribri@bribri1:~$ sudo ufw default deny incoming
Default incoming policy changed to 'deny'
(be sure to update your rules accordingly)
bribri@bribri1:~$ sudo ufw default allow outgoing
Default outgoing policy changed to 'allow'
(be sure to update your rules accordingly)
bribri@bribri1:~$
```

➤ **Autoriser uniquement les ports nécessaires :**

```
bribri@bribri1:~$ sudo ufw allow 2222/tcp
Rule added
Rule added (v6)
bribri@bribri1:~$ sudo ufw allow 80/tcp
Rule added
Rule added (v6)
bribri@bribri1:~$ sudo ufw allow 443/tcp
Rule added
Rule added (v6)
bribri@bribri1:~$ _
```

➤ **Activer le firewall**

```
bribri@bribri1:~$ sudo ufw enable
Firewall is active and enabled on system startup
```

➤ **Vérifier les règles actives :**

```
bribri@bribri11:~$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
22 ALLOW IN Anywhere
80 ALLOW IN Anywhere
443 ALLOW IN Anywhere
2222/tcp ALLOW IN Anywhere
80/tcp ALLOW IN Anywhere
443/tcp ALLOW IN Anywhere
22 (v6) ALLOW IN Anywhere (v6)
80 (v6) ALLOW IN Anywhere (v6)
443 (v6) ALLOW IN Anywhere (v6)
2222/tcp (v6) ALLOW IN Anywhere (v6)
80/tcp (v6) ALLOW IN Anywhere (v6)
443/tcp (v6) ALLOW IN Anywhere (v6)

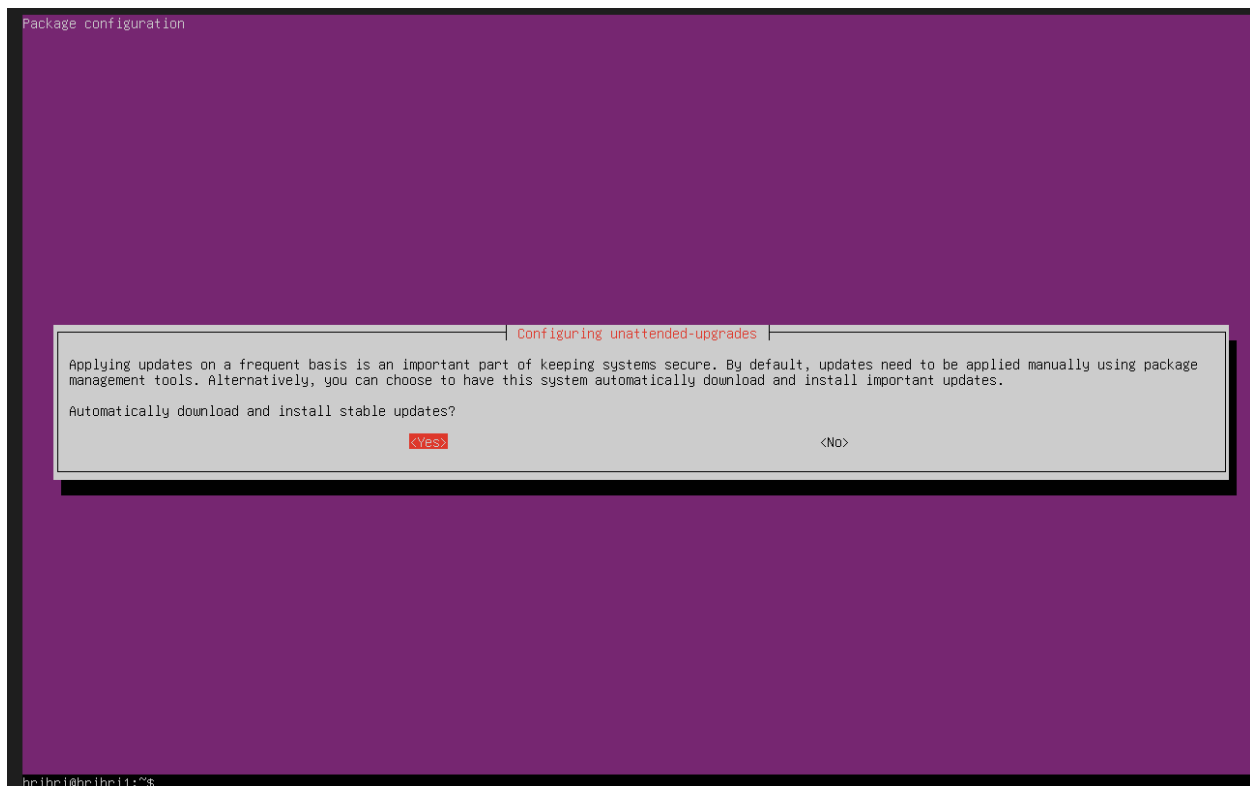
bribri@bribri11:~$
```

➤ Activer les mises à jours automatiques

```
bribri@bribri11:~$ sudo apt install unattended-upgrades -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
unattended-upgrades is already the newest version (2.9.1+nmu4ubuntu1).
0 upgraded, 0 newly installed, 0 to remove and 6 not upgraded.
bribri@bribri11:~$ sudo dpkg-reconfigure --priority=low unattended-upgrades
```

```
bribri@bribri11:~$ sudo apt install apt-listchanges
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
apt-listchanges is already the newest version (3.27).
0 upgraded, 0 newly installed, 0 to remove and 6 not upgraded.
bribri@bribri11:~$ sudo systemctl status unattended-upgrades
• unattended-upgrades.service - Unattended Upgrades Shutdown
  Loaded: loaded (/usr/lib/systemd/system/unattended-upgrades.service; enabled; preset: enabled)
  Active: active (running) since Fri 2026-04-03 14:53:44 UTC; 2h 57min ago
    Docs: man:unattended-upgrade(8)
  Main PID: 760 (unattended-upgr)
    Tasks: 2 (limit: 4601)
  Memory: 12.0M (peak: 12.5M)
    CPU: 381ms
  CGroup: /system.slice/unattended-upgrades.service
          └─760 /usr/bin/python3 /usr/share/unattended-upgrades/unattended-upgrade-shutdown --wait-for-signal

Apr 03 14:53:44 bribri11 systemd[1]: Started unattended-upgrades.service - Unattended Upgrades Shutdown.
bribri@bribri11:~$ _
```



➤ Vérification des permissions sensibles

```
bribri@bribri1:~$ chmod 700 ~/.ssh
bribri@bribri1:~$ chmod 600 ~/.ssh/authorized_keys
bribri@bribri1:~$ ls -l /etc/passwd /etc/shadow
-rw-r--r-- 1 root root 1940 Mar 29 21:39 /etc/passwd
-rw-r----- 1 root shadow 1030 Mar 29 21:39 /etc/shadow
bribri@bribri1:~$ sudo chmod 644 /etc/passwd
bribri@bribri1:~$ sudo chmod 640 /etc/shadow
bribri@bribri1:~$ _
```

➤ Vérifier l'espace du disque

```
bribri@bribri1:~$ sudo apt install logrotate
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
logrotate is already the newest version (3.21.0-2build1).
0 upgraded, 0 newly installed, 0 to remove and 6 not upgraded.
bribri@bribri1:~$ _
```

➤ Liste des services actifs :

```

apache-htcacheclean@.service      disabled enabled
apache2.service                  enabled enabled
apache2@.service                  disabled enabled
apparmor.service                 enabled enabled
apport-autoreport.service         static -
apport-coredump-hook@.service     static -
apport-forward@.service           static -
apport.service                   enabled enabled
apt-daily-upgrade.service         static -
apt-daily.service                static -
apt-news.service                 static -
autovt@.service                  alias -
blk-availability.service          enabled enabled
bolt.service                      static -
cloud-config.service             enabled enabled
cloud-final.service              enabled enabled
cloud-init-hotplugd.service       static -
cloud-init-local.service          enabled enabled
cloud-init.service               enabled enabled
console-getty.service            disabled disabled
console-setup.service            enabled enabled
container-getty@.service          static -
cron.service                     enabled enabled
cryptdisks-early.service          masked enabled
cryptdisks.service               masked enabled
dbus-org.freedesktop.hostname1.service alias -
dbus-org.freedesktop.locale1.service alias -
dbus-org.freedesktop.login1.service alias -
dbus-org.freedesktop.ModemManager1.service alias -
dbus-org.freedesktop.resolve1.service alias -
dbus-org.freedesktop.thermald.service alias -
dbus-org.freedesktop.timedate1.service alias -
dbus-org.freedesktop.timesync1.service alias -
dbus.service                     static -
debug-shell.service              disabled disabled
dm-event.service                 static -
dmesg.service                    enabled enabled
dpkg-db-backup.service           static -
e2scrub@.service                  static -
e2scrub_all.service              static -
e2scrub_fail@.service             static -
e2scrub_reap.service             enabled enabled
emergency.service                static -
esm-cache.service                static -
fail2ban.service                 enabled enabled
finalrd.service                  enabled enabled
friendly-recovery.service         static -

[2]+  Stopped                  systemctl list-unit-files --type=service
br1bri@br1bri1:~$

```

➤ Audit après durcissement

```

Solution : Installer d'abord l'outil Lynis, en mode local, comme :
https://cisofy.com/lynis/controls/HRDN-7230/

Follow-up:
-----
- Show details of a test (lynis show details TEST-ID)
- Check the logfile for all details (less /var/log/lynis.log)
- Read security controls texts (https://cisofy.com)
- Use --upload to upload data to central system (Lynis Enterprise users)

=====

Lynis security scan details:

Hardening index : 63 [##### ]
Tests performed : 268
Plugins enabled : 1

Components:
- Firewall [V]
- Malware scanner [X]

Scan mode:
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat

=====

Lynis 3.0.9

Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

2007-2021, CISofy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)

=====

[TIP]: Enhance Lynis audits by adding your settings to custom.prfl (see /etc/lynis/default.prfl for all settings)

br1bri@br1bri1:~$ _

```

1. Pourquoi les mises à jour automatiques sont-elles importantes en production ?

Les mises à jour automatiques sont cruciales en production car les failles de sécurité sont découvertes en permanence. Sans correctifs rapides, un serveur exposé sur Internet devient vulnérable à des attaques exploitant ces failles connues. Le service `unattended-upgrades` applique automatiquement les mises à jour de sécurité sans intervention humaine, réduisant ainsi la fenêtre d'exposition. En production, on ne peut pas se permettre d'attendre qu'un administrateur soit disponible pour patcher manuellement.

2. Quel est le rôle d'un IDS comme AIDE ?

AIDE (Advanced Intrusion Detection Environment) est un système de détection d'intrusion basé sur l'intégrité des fichiers. Il crée une base de données de référence (empreintes cryptographiques) de tous les fichiers système. À chaque scan suivant, il compare l'état actuel à cette référence et signale toute modification suspecte : fichier modifié, ajouté ou supprimé. Cela permet de détecter une intrusion ou une compromission du système même après le fait.

3. Pourquoi sécuriser les permissions des fichiers système ?

Des permissions trop permissives sur des fichiers sensibles comme `/etc/shadow` (qui contient les mots de passe hashés) ou `~/.ssh/authorized_keys` peuvent permettre à un utilisateur non autorisé de lire, modifier ou remplacer ces fichiers. Par exemple, si `/etc/shadow` est lisible par tous, un attaquant peut tenter de cracker les mots de passe hors ligne. Les bonnes permissions (640 pour `shadow`, 700 pour `.ssh`, 600 pour les clés) limitent l'accès au strict nécessaire du principe du moindre privilège.

4. Peut-on considérer un serveur totalement sécurisé ?

Non, un serveur ne peut jamais être considéré comme totalement sécurisé. La sécurité est un processus continu, pas un état final. De nouvelles vulnérabilités (zero-days) sont découvertes régulièrement, les configurations peuvent dériver, et le facteur humain reste une source d'erreurs. L'objectif est de réduire au maximum la surface d'attaque, de détecter rapidement les incidents et de réagir efficacement, c'est pourquoi les audits réguliers avec Lynis, la surveillance des logs et les mises à jour automatiques sont essentiels.

Conclusion

Ce TD m'a permis de comprendre concrètement l'importance d'un audit de sécurité sur un serveur Linux avant sa mise en production. Grâce à l'outil Lynis, j'ai pu analyser l'état initial du système, identifier les failles les plus fréquentes (mises à jour manquantes, configuration SSH trop permissive, services inutiles) et appliquer des mesures correctives adaptées. Le durcissement du serveur, notamment par la sécurisation de SSH, la mise en place d'un pare-feu, la gestion des permissions et l'activation des mises à jour automatiques, a conduit à une amélioration notable du score de sécurité. Ce travail m'a montré que la sécurité est un processus continu, qui nécessite des audits réguliers et une vigilance permanente pour garantir la fiabilité et la protection des infrastructures informatiques.